MANAGEMENT DECISION · GENERAL EDITION

# Security proposal for management

One shared foundation. Three complete protection packages.

Maximum 100 administrators | 2FA in every option | No additional servers to operate

Choose the common foundation plus one proposal. These are design recommendations, not implemented controls or a full cost quotation. Each item has two sentences and linked supporting evidence.

Strategy citations stay in this site and provide a return link. External sources open a new tab. In PDF and Markdown exports, strategy citations open the published general strategy so they work wherever the files are saved.

## Contents


Common foundation

Proposal 1 · Lean AWS

Proposal 2 · AWS edge

Proposal 3 · Existing edge

Budget worksheet

01 · COMMON FOUNDATION

# Protect the organization and every AWS account

## 01 Named owners and time-limited exceptions

Assign named owners for AWS administration, security incidents and billing, and require someone other than the author to approve production changes. [Strategy: Ownership and approvals] Keep a control register showing who is responsible, evidence that each control works, and an approver and expiry date for every exception. [Strategy: Incident alerts]

## 02 Separate accounts for production, security and recovery

Create separate AWS accounts for management, production, development, security tools, logs and backups, keeping application workloads out of the management account. [Strategy: Account security] Keep production data out of development and deny application roles permission to alter the separate log and backup stores, limiting the damage from a compromised application. [Strategy: Account security]

## 03 Block dangerous account actions with SCPs

Apply AWS Organizations service control policies (SCPs) to stop member-account administrators from disabling security monitoring, creating permanent access keys, leaving the organization or deploying outside approved regions. [Strategy: Account security] Test narrowly defined exceptions for essential AWS services and approved security automation before enforcement, so these restrictions do not block normal operation or recovery. [Strategy: Region safeguards]

## 04 Reject unauthorized access from outside the organization

Use resource control policies (RCPs) to reject access to supported S3 storage, encryption keys and secrets from identities outside our AWS organization. [Strategy: Data boundaries] Inventory external access first and explicitly allow approved partner and AWS service integrations, so legitimate log delivery and backups continue while unapproved outsiders are blocked. [Strategy: Account security]

## 05 Make storage private and encrypted by default

Enable account-wide S3 Block Public Access and default disk encryption, and prohibit public sharing of machine images and disk snapshots. [Strategy: Account security] Apply these settings through centrally controlled policies and repeatable Terraform configuration, so new resources receive the same protections without relying on someone remembering each setting. [Strategy: Account security]

## 06 Named logins, mandatory 2FA and limited privileges

Use IAM Identity Center for named AWS logins and require two-factor authentication for every administrator, with security keys or passkeys for the most powerful roles. [Strategy: Identity controls] Make production access read-only by default, limit elevated AWS sessions to one hour, review permissions quarterly and remove access when someone leaves. [Strategy: Account security]

## 07 Protect the AWS owner accounts and emergency access

Limit management-account access to two named administrators and protect its root user, the unrestricted account owner, with two hardware authentication keys stored separately. [Strategy: Account security] Remove standing root credentials from member accounts through centralized root management, and maintain tested emergency identities that alert the security owner whenever used. [Strategy: Identity controls]

## 08 Keep a protected record of who changed what

Use CloudTrail to record who changed AWS resources and AWS Config to record their settings, sending both to the separate log account. [Strategy: Audit trail] Protect security logs against early deletion with S3 Object Lock, retain one year readily accessible plus six years archived, and exclude passwords and tokens. [Strategy: Logging]

## 09 24/7 alerts with a 15-minute acknowledgement target

Use GuardDuty to flag suspected attacks, Inspector to find vulnerable software, and Config with Security Hub to report unsafe settings across accounts. [Strategy: Logging] Route suspected compromise to an on-call responder 24/7, with a 15-minute acknowledgement target and a named owner for lower-priority fixes. [Strategy: Incident alerts]

## 10 Keep 35 days of backups and test recovery quarterly

Use AWS Backup for daily database snapshots retained for 35 days, with copies in the separate backup account protected against early deletion by Vault Lock. [Strategy: Data protection] Restore a backup every quarter, record the recovery time and potential data loss, and have the business approve whether those results meet the service requirements. [Strategy: Recovery]

## 11 Deploy reviewed changes without permanent access keys

Deploy account and network changes from reviewed Terraform code through GitHub Actions, using temporary AWS credentials instead of stored access keys. [Strategy: Deployment identity] Require a second approver for changes to account policies, network routes or administrative access, and alert security if these controls change outside the approved process. [Strategy: Account security]

## 12 Alert on unexpected spending and review the full bill

Set AWS Budgets for each account and use Cost Anomaly Detection to notify billing and security owners about unexpected spending, including possible misuse of stolen credentials. [Strategy: Cost alerts] Review actual monthly costs against the worksheet, including logs, backups, licences and staff time; budget alerts warn people but do not automatically cap spending. [Strategy: Cost alerts]

## 13 Require test results before approving launch

Require a penetration test and retest of serious findings, a backup-restore exercise and a peak-traffic test that includes the emergency fallback page. [Strategy: Launch tests] Reject launch if unauthorized users can change guidance, backups cannot be restored or the emergency fallback fails, and present management with the test evidence. [Strategy: Launch tests]

# Start with the lowest-complexity AWS package

## 01 Best fit and trade-off

Choose this as the budget-first candidate when direct access through the public AWS load balancer passes the peak-traffic and security tests. [Strategy: Network protection] It avoids an additional public edge vendor, but gives up the extra caching layer in Proposal 2 and the vendor support arrangement in Proposal 3. [Strategy: Emergency fallback]

## 02 Filter attacks at the public entrance

Put AWS WAF on the public load balancer with managed attack rules, allowed website paths and carefully tested request limits. [Strategy: Web attack protection] Use the included AWS network-attack protection as a baseline, without presenting it as a guarantee against every outage or application attack. [AWS DDoS protection]

## 03 Keep emergency information reachable

Do not block public guidance just because the visitor appears to be in another country, because legitimate roaming users can appear abroad. [Strategy: Web attack protection] Check submitted locations in the application and use stricter limits for suspicious writes rather than placing puzzles in front of emergency reading. [Strategy: Web attack protection]

## 04 Private administrator access with two factors

Use AWS Verified Access in front of the internal administrator load balancer and require two-factor sign-in through the chosen identity provider. [Strategy: Mandatory 2FA] Give each administrator only the permitted application actions and validate the signed identity rather than assuming a successful sign-in grants full authority. [Strategy: Application identity]

## 05 Technical access without a jump server

Budget for two managed Verified Access connections for the cluster and database, with local client software only for technical administrators. [Strategy: Administrator access] Use CloudShell inside the private network as a tested alternative where browser-based command-line work is sufficient, and verify region, identity and workstation compatibility before purchase. [AWS access client]

## 06 Separate public and administrative workloads

Keep application servers and databases on private networks and allow communication only between components that actually need it. [Strategy: Network protection] Use separate public and administrative workload groups, encrypted connections and default-deny network rules to limit the damage from a compromised component. [Strategy: Workload identities]

## 07 Small permissions for every component

Give each workload its own Kubernetes service identity and AWS permissions instead of sharing a powerful account. [Strategy: Workload identities] Give public services, administrative services and database migrations separate database logins with only the required reading or writing rights. [Strategy: Database permissions]

## 08 Protect sensitive information

Encrypt stored data and connections, keep passwords in Secrets Manager and rotate them through an approved process. [Strategy: Data protection] Collect only the personal information needed for the service and delete or aggregate it after the approved retention period. [Strategy: Data retention]

## 09 Deploy only checked software

Use maintained minimal container images, scan them for vulnerabilities and verify the signature of each released image. [Strategy: Container protection] Remove debugging access and privileged execution, enforce admission rules in the existing cluster and retain a tested rollback. [Strategy: Secure delivery]

## 10 Detect and recover inside the application

Send suspicious sign-ins, unexpected guidance changes and workload threats into the common alerting process, with a named responder and a short playbook. [Strategy: Incident alerts] Keep a separately hosted emergency information page and test switching to it when the normal application is unavailable. [Strategy: Emergency fallback]

## 11 Cost checkpoint, not a complete quote

At the cited example rates and 730 hours, one Verified Access web application plus two technical endpoints costs about USD 489 per month before usage and other services. [Verified Access pricing] A standard WAF example with one web ACL and ten billable rule entries adds USD 15 per month plus USD 0.60 per million inspected requests, with extra features and the administrator ACL priced separately. [AWS WAF pricing]

## 12 What the team still owns

This package adds no jump server, proxy server or separate monitoring server, but the existing application and Kubernetes workloads still need maintenance. [Strategy: Responsibilities] The team remains responsible for access policies, firewall tuning, client updates, incident response and a staged migration away from the existing edge arrangement. [Strategy: Access options]

## 13 Management approval condition

Approve this package only if the production-like traffic test shows that the public application and emergency fallback remain usable without an extra caching layer. [Strategy: Launch tests] If that test fails or the overall cost model favours caching, select Proposal 2 rather than removing essential security controls to stay within budget. [CloudFront pricing]

# Add a managed edge for a surge-heavy public service

## 01 Best fit and trade-off

Choose this when reducing public traffic reaching the application is worth an additional managed delivery layer. [CloudFront pricing] It combines CloudFront, AWS WAF and Verified Access without a self-managed proxy, but its value depends on measured traffic and what can safely be cached. [Strategy: Access options]

## 02 Stop unwanted traffic before it reaches the application

Put CloudFront and AWS WAF in front of the public load balancer, using managed attack rules, approved routes and tested request limits. [Strategy: Web attack protection] Restrict the load balancer to CloudFront traffic and require a protected origin header so attackers cannot simply bypass the edge. [AWS origin protection]

## 03 Cache public content, never private responses

Cache public images, scripts and approved guidance content while keeping private responses, administration and personal location submissions out of shared caches. [CloudFront pricing] Define how quickly changed guidance becomes visible and rehearse emergency updates so caching cannot serve dangerously outdated instructions. [Strategy: Guidance integrity]

## 04 Protect visitors without blocking legitimate help

Keep public guidance available to roaming visitors and validate reported locations inside the application. [Strategy: Web attack protection] Apply stronger controls to suspicious submissions while using administrator location restrictions only as an extra check alongside mandatory two-factor authentication. [Strategy: Location controls]

## 05 Private administrator access with two factors

Use Verified Access for the internal administrator application, with mandatory two-factor sign-in and separate permissions for each administrator group. [Strategy: Mandatory 2FA] Verify the application identity and signed claims, keep sessions short and alert on unusual sign-ins or changes to published guidance. [Strategy: Application identity]

## 06 No additional server for technical access

Use managed Verified Access endpoints for the private cluster and database and install the client only on technical administrators' supported devices. [Strategy: Administrator access] Test the chosen identity provider and retain a separately authenticated CloudShell recovery path where region availability and the required commands have been confirmed. [AWS access client]

## 07 Contain an internal compromise

Keep application workloads and databases private, separating public services from administrative services with default-deny network rules. [Strategy: Network protection] Encrypt internal connections and allow each component to contact only its approved dependencies. [Strategy: Internal encryption]

## 08 Separate workload and database identities

Give each workload its own service account and narrow AWS permissions. [Strategy: Workload identities] Use separate database users for public services, administrators and migrations so a public-service weakness cannot inherit database-owner powers. [Strategy: Database permissions]

## 09 Reduce the information at risk

Encrypt data, keep credentials in Secrets Manager and limit access to personal information. [Strategy: Data protection] Apply approved retention and deletion rules, and verify that logs and CloudFront caches do not retain information they should not contain. [Strategy: Data retention]

## 10 Keep unsafe software out

Build from maintained minimal images, scan releases and accept only approved signed images in the existing cluster. [Strategy: Container protection] Run applications without unnecessary privileges, remove debugging ports and preserve a tested deployment rollback. [Strategy: Secure delivery]

## 11 Managed detection and a separate fallback

Feed edge, administrator and workload incidents into the common alert-only response process instead of building a staffed monitoring room. [Strategy: Incident alerts] Host the emergency page independently of the application cluster and rehearse how it stays reachable and current during an incident. [Strategy: Emergency fallback]

## 12 Compare total edge cost before buying

Budget about USD 489 per month for the example Verified Access configuration, then compare CloudFront pay-as-you-go with eligible flat-rate plans using normal and emergency traffic forecasts. [Verified Access pricing] Check which firewall features, logs and usage are included so the budget neither double-counts bundled protection nor treats the smallest plan as adequate for an emergency surge. [CloudFront pricing]

## 13 What the team still owns

AWS operates the delivery and access services, but the team still maintains the existing application, cluster policies, caching rules and administrator devices. [Strategy: Launch tests] Approve this package only after the traffic model, origin-bypass test, cache-update test and residency review justify its cost over Proposal 1. [AWS origin protection]

# Retain Imperva where its contract justifies the cost

## 01 Best fit and trade-off

Choose this when retaining the existing Imperva arrangement avoids a costly migration or provides contractually valuable incident support. [Strategy: Imperva decision] Do not assume it is cheaper or more secure merely because it uses two vendors, and obtain a written price and service-scope confirmation. [Strategy: Web attack protection]

## 02 Use the existing edge as the first filter

Keep Imperva as the public entry point for web attacks, unwanted bots and traffic-flood protection under the selected service contract. [Strategy: Web attack protection] Confirm which rules, support services, traffic allowances and emergency response commitments are actually included rather than relying on product names or defaults. [Strategy: Imperva decision]

## 03 Do not let attackers go around Imperva

Restrict the public AWS load balancer to the approved Imperva paths and verify the origin connection with an approved protected mechanism. [Strategy: Origin protection] Keep AWS WAF at the origin for application-specific routes and attack rules, but do not blindly duplicate all filtering at both layers. [Strategy: Web attack protection]

## 04 Apply visitor checks where the real visitor is visible

Use Imperva for public client reputation and location checks because the origin otherwise sees the proxy address. [Strategy: Visitor reputation] Keep public emergency reading open to legitimate roaming users and validate submitted locations inside the application. [Strategy: Web attack protection]

## 05 Keep administration separate from the public edge

Use Verified Access with mandatory two-factor authentication in front of the internal administrator application rather than exposing the console through the public website. [Strategy: Mandatory 2FA] Give each administrator group only its own actions and validate signed identity claims in the application. [Strategy: Application identity]

## 06 Technical access without a server to maintain

Use two managed Verified Access endpoints for cluster and database access, with client software only for the technical administrators who need it. [Strategy: Administrator access] Validate identity-provider and workstation compatibility, and rehearse CloudShell recovery with independently protected emergency credentials. [AWS access client]

## 07 Contain attacks after the public boundary

Keep workloads and databases private and separate public services from administrative services with narrow network permissions. [Strategy: Network protection] Encrypt internal traffic and block unnecessary outbound communication so an infected component has fewer places to reach. [Strategy: Outbound restrictions]

## 08 Avoid shared powerful accounts

Use one Kubernetes identity and narrow AWS permissions per workload. [Strategy: Workload identities] Use different database logins for public services, administration and migrations, with the database-owner account kept out of normal application use. [Strategy: Database permissions]

## 09 Protect personal data across both providers

Encrypt data, store credentials securely and apply approved retention limits to the application and its logs. [Strategy: Data protection] Review where Imperva processes traffic and stores logs, and approve the required privacy terms and regional exceptions before deployment. [Strategy: Residency]

## 10 Enforce safe releases internally

Use maintained minimal images, vulnerability checks, signed releases and admission rules in the existing cluster. [Strategy: Container protection] Remove privileged execution and debugging access while retaining a tested rollback for application changes. [Strategy: Secure delivery]

## 11 One response process across two vendors

Send Imperva, AWS and application alerts to the same assigned responders with clear instructions for contacting each provider. [Strategy: Incident alerts] Test a separately hosted emergency page and a joint incident exercise so a provider hand-off does not delay recovery. [Strategy: Emergency fallback]

## 12 Price the contract and the duplicate inspection

Add the quoted Imperva service and support costs to the example USD 489 monthly Verified Access configuration and the selected AWS firewall, logging and detection charges. [Strategy: Imperva decision] Compare that total and the migration avoided against Proposals 1 and 2, including traffic overages, contract commitments and incident support. [Verified Access pricing]

## 13 What management must accept

No new self-managed connector or jump server is required, but the team still operates the existing workloads and coordinates policies and incidents across AWS and Imperva. [Strategy: Web attack protection] Approve this package only when the contract, tested protection and migration savings justify that additional cost and coordination. [Strategy: Responsibilities]

BUDGET WORKSHEET · INSIDE THIS PROPOSAL

# Common costs + your chosen option

Every field starts with an editable estimate so you can compare Common plus each option immediately. These are **planning estimates, not approved budgets or vendor quotes**; clearing a field makes it unpriced, not free.

## Simple planning assumptions

USD per month, 730 hours, at most 100 administrators, one web access application and two technical endpoints. Rates were checked on 22 October 2026 against Verified Access pricing and WAF pricing; confirm deployment-region rates before approval.

**Public requests per month, in millions** 10

Ten million requests is a comparison example, not a forecast from the administrator count or the emergency-user count. WAF examples assume one ACL and ten billable rule entries per inspected layer; advanced rules, challenges and extra inspection can cost more.

The basis notes explain the starting estimates; if you edit a field, they do not become a new quote or automatically change the assumed scope. Labour uses a planning rate of USD 100 per hour, and routine operations assume existing on-call coverage.

## Common · pay once, whichever option you choose

| Cost item | Monthly USD | Basis |
|---|---|---|
| **Account safeguards** | USD 0.00 | Organizations has no additional service charge; configuration work is below. |
| **Threat detection and security checks** | USD 300.00 | Planning allowance: GuardDuty 100 + Security Hub 100 + Inspector 50 + Config 50 per month; validate against actual account and workload usage. See usage pricing. |
| **Logs, backups and other security usage** | USD 250.00 | Planning allowance: logs and retention 75 + backups 125 + keys, secrets and access usage 50 per month; validate storage growth and restore costs. See log pricing. |
| **Ongoing security operations** | USD 1,200.00 | Planning allowance: 12 hours per month × USD 100 for reviews, patching and routine response; assumes an existing on-call team, not new 24/7 staffing. |
| **Additional identity licences** | USD 300.00 | Planning allowance: 100 administrators × USD 3 per month for any additional identity licences; not a vendor price, and removable if existing licences suffice. IAM Identity Center itself has no extra charge. |
| Shared setup and security assessment · one-time USD<br>Planning allowance: 40 hours × USD 100 for shared controls, plus USD 4,000 for penetration testing and retesting; replace with scoped estimates. | | USD 8,000.00 |

Common priced subtotal: **USD 2,050.00 (estimate)** per month.

## Proposal 1 · Lean AWS

| Cost item | Monthly USD | Basis |
|---|---|---|
| **Verified Access web application** | USD 197.10 | 730 hours × USD 0.27; private administrator website. |
| **Verified Access technical connections** | USD 292.00 | Two endpoints × 730 hours × USD 0.20; cluster and database. |
| **Administrator web firewall** | USD 15.60 | One ACL, ten billable rule entries, one million requests. |
| **Public web firewall** | USD 21.00 | USD 5 + ten rule entries + USD 0.60 per million public requests. |
| Implementation and testing for this option · one-time USD<br>Planning allowance: 20 hours × USD 100 for access, firewall configuration and testing. | | USD 2,000.00 |

Option-only priced subtotal: **USD 525.70 (estimate)** per month, before Common.

## Proposal 2 · AWS edge

| Cost item | Monthly USD | Basis |
|---|---|---|
| **Verified Access web application** | USD 197.10 | 730 hours × USD 0.27; private administrator website. |
| **Verified Access technical connections** | USD 292.00 | Two endpoints × 730 hours × USD 0.20; cluster and database. |
| **Administrator web firewall** | USD 15.60 | One ACL, ten billable rule entries, one million requests. |
| **CloudFront package including public WAF** | USD 200.00 | Business plan example: USD 200; confirm required features and traffic limits before choosing it. |
| Implementation and testing for this option · one-time USD<br>Planning allowance: 30 hours × USD 100 for access, edge configuration and testing. | | USD 3,000.00 |

Option-only priced subtotal: **USD 704.70 (estimate)** per month, before Common.

Proposal 2 counts public WAF inside the example CloudFront package, not again as a separate charge. If choosing pay-as-you-go instead, enter the combined CDN and public WAF estimate in that field.

## Proposal 3 · Existing edge

| Cost item | Monthly USD | Basis |
|---|---|---|
| **Verified Access web application** | USD 197.10 | 730 hours × USD 0.27; private administrator website. |
| **Verified Access technical connections** | USD 292.00 | Two endpoints × 730 hours × USD 0.20; cluster and database. |
| **Administrator web firewall** | USD 15.60 | One ACL, ten billable rule entries, one million requests. |
| **AWS firewall at the public origin** | USD 21.00 | Conservative example: all entered public requests reach this inspection layer. |
| **Imperva service and support** | USD 1,000.00 | Planning placeholder: USD 1,000 per month for service and support, not an Imperva quote; replace with the actual contract cost. |
| Implementation and testing for this option · one-time USD<br>Planning allowance: 30 hours × USD 100 for access, vendor integration and testing. | | USD 3,000.00 |

Option-only priced subtotal: **USD 1,525.70 (estimate)** per month, before Common.

## Decision total

**Common + Proposal 1: USD 2,575.70 (estimate) per month. First year, including one-time costs: USD 40,908.40 (estimate).**

| Common + option | Monthly | Yearly recurring | One-time |
|---|---|---|---|
| **Proposal 1** | USD 2,575.70 (estimate) | USD 30,908.40 (estimate) | USD 10,000.00 (estimate) |
| **Proposal 2** | USD 2,754.70 (estimate) | USD 33,056.40 (estimate) | USD 11,000.00 (estimate) |
| **Proposal 3** | USD 3,575.70 (estimate) | USD 42,908.40 (estimate) | USD 11,000.00 (estimate) |

Totals are incremental security planning estimates, not a full website-running-cost quote. Existing application hosting, load balancers, database and cluster capacity, taxes and general internet delivery are excluded unless explicitly included in a package; do not count the same cost twice.

The Common usage allowance includes a starter amount for access data processing and connection charges; increase it when usage is known. Confirm licences, emergency capacity, retention volumes, support and migration scope before approval; the estimate includes no contingency or separately purchased 24/7 response service.